UNIT 3 · TOPIC 3.4

Firewall Access Controls

Quiz

Instructions: This quiz has 18 multiple-choice questions, 1 point each. Circle the letter of the single best answer for each question.

Name: **Date:** **Class:**

1. Which of the following best describes a stateless packet-filtering firewall?

- ○ A. It operates at the application layer and can inspect the content of HTTP requests for malicious payloads.
- ○ B. It maintains a record of active connections and automatically allows return traffic for established sessions.
- ○ C. It inspects each packet independently based on header fields such as source IP, destination IP, and port number, without tracking connection state.
- ○ D. It encrypts all outbound packets before forwarding them to the next network segment.

2. Which of the following is a capability of a next-generation firewall (NGFW) that is NOT available in a traditional stateless packet-filtering firewall?

- ○ A. Blocking traffic by destination port number
- ○ B. Applying rules based on source IP address ranges
- ○ C. Deep packet inspection of application-layer payloads
- ○ D. Denying all inbound ICMP traffic

3. Which type of firewall intercepts all traffic between a client and a server, makes requests on the client's behalf, and thereby hides internal IP addresses from external hosts?

- ○ A. Stateful inspection firewall
- ○ B. Stateless packet-filtering firewall
- ○ C. Application proxy firewall
- ○ D. Unified Threat Management (UTM) device

4. A firewall's ACL contains the following three rules applied top-to-bottom:

1. **Permit TCP any → 192.168.10.5 port 443**
2. **Permit TCP any → 192.168.10.5 port 80**
3. **Deny IP any any**

Which statement best explains the behavior of this ACL?

- ○ A. All traffic destined for 192.168.10.5 is permitted, regardless of protocol or port.
- ○ B. UDP traffic to 192.168.10.5 on port 443 is permitted by rule 1 because the port number matches.
- ○ C. The deny rule at position 3 prevents rules 1 and 2 from ever being evaluated.
- ○ D. HTTPS and HTTP traffic to 192.168.10.5 is permitted; all other traffic is denied by the catch-all rule.

5. Adams County Hospital has a public web server (203.0.113.10) and an internal patient-records file server (10.0.0.5). A network engineer is deploying two firewalls: Firewall A between the internet and a DMZ, and Firewall B between the DMZ and the internal LAN.

Which placement strategy best implements defense-in-depth for this architecture?

- ○ A. Firewall A filters all external traffic; Firewall B is configured to allow all DMZ-to-LAN traffic by default to avoid impeding clinical staff.
- ○ B. Firewall A restricts inbound internet traffic to the web server on permitted ports only; Firewall B independently restricts DMZ-to-LAN traffic to only permitted internal services.
- ○ C. Both firewalls use identical ACLs to ensure consistent rule enforcement across both boundaries.
- ○ D. Firewall A handles all inbound traffic; Firewall B handles all outbound traffic, with no overlap in rule scope.

6. Which of the following best explains why security best practice recommends including an explicit "Deny IP any any" rule at the end of a firewall ACL, even though most firewalls already apply an implicit deny to unmatched traffic?

- ○ A. It makes the deny policy visible in firewall logs, creating an audit trail of all blocked traffic that auditors and incident responders can review.
- ○ B. It accelerates rule processing by giving the firewall a defined terminal condition that stops evaluation early.
- ○ C. It prevents the firewall from forwarding any traffic until at least one permit rule has been matched first.
- ○ D. It overrides all preceding permit rules, giving administrators a quick kill-switch to shut down all traffic in an emergency.

7. A security team reviewing Adams County Hospital's network proposes removing Firewall B, the firewall between the DMZ and the internal LAN, to reduce latency for clinical staff accessing the patient-records file server.

Which evaluation of this proposal is most accurate?

- ○ A. The proposal is sound because Firewall A already filters all external threats before they reach the internal network.
- ○ B. The proposal is acceptable provided the web server runs host-based intrusion detection software to compensate.
- ○ C. The proposal is acceptable because the file server's operating system firewall can enforce equivalent access restrictions.
- ○ D. The proposal eliminates a critical security layer; a compromised DMZ web server could then move laterally to the file server containing protected health information with no intervening control.

8. When evaluating firewall placement strategies, which of the following best describes the primary risk of connecting a public-facing web server directly to the internal LAN (with no DMZ) when only a single perimeter firewall is deployed?

- ○ A. The web server will be unable to serve HTTPS traffic because the perimeter firewall will block port 443 inbound.
- ○ B. Without a DMZ, the perimeter firewall cannot perform stateful inspection.
- ○ C. Firewall processing overhead increases significantly because the firewall must perform deep inspection on all HTTP traffic to the web server.
- ○ D. The inbound port rules required to serve public traffic create a pathway that, if exploited, could enable an attacker to reach all other systems on the same internal network segment.

9. A HIPAA-covered healthcare organization is evaluating three firewall strategies:

Strategy 1: Single perimeter firewall with all servers on a flat internal LAN.
Strategy 2: Dual-firewall DMZ, public servers in the DMZ, patient-record systems on a separate internal LAN behind a second firewall.
Strategy 3: Single next-generation firewall (NGFW) with deep packet inspection at the perimeter only; no DMZ.

Which evaluation correctly identifies the most appropriate strategy and its primary justification?

- ○ A. Strategy 1 is best because it minimizes rule complexity and reduces administrative overhead.
- ○ B. Strategy 2 is best because it isolates public-facing infrastructure from systems containing protected health information, providing segmented defense-in-depth at the network layer.
- ○ C. Strategy 3 is best because NGFW deep packet inspection eliminates the need for physical or logical network segmentation.
- ○ D. All three strategies are equivalent in security if the firewall ruleset is sufficiently strict.

10. Which of the following ACL entries correctly permits only inbound HTTPS traffic from any external host to the web server at 203.0.113.10?

- ○ A. Permit TCP any → 203.0.113.10 port 443
- ○ B. Permit UDP any → 203.0.113.10 port 443
- ○ C. Permit TCP any → 203.0.113.10 port 80
- ○ D. Permit IP any → 203.0.113.10

11. Which of the following best describes the primary purpose of enabling logging on firewall rules?

- ○ A. Logging creates a timestamped audit trail of permitted and denied traffic that can be used for incident investigation and compliance reporting.
- ○ B. Logging speeds up packet processing by caching the results of frequently matched rules.
- ○ C. Logging automatically blocks repeated connection attempts from the same source IP address.
- ○ D. Logging encrypts sensitive traffic headers before the firewall forwards packets to internal systems.

12. A firewall rule reads: "Deny TCP 10.0.0.0/8 → any port 23." What traffic does this rule block?

- ○ A. All outbound traffic originating from any host within the 10.0.0.0/8 network
- ○ B. All TCP traffic between the 10.0.0.0/8 network and the internet, regardless of port
- ○ C. SSH traffic from any external host destined for the 10.0.0.0/8 network on port 23
- ○ D. Telnet traffic originating from any host within the 10.0.0.0/8 internal network destined for any external host

13. Firewall A at Adams County Hospital must allow external patients to access the appointment web server (203.0.113.10) over HTTPS only, while blocking all other inbound traffic. The firewall is stateful.

Which pair of ACL rules, applied in order, correctly implements this requirement?

- ○ A. Rule 1: Permit TCP any → 203.0.113.10 port 443 | Rule 2: Deny IP any any
- ○ B. Rule 1: Permit IP any → 203.0.113.10 | Rule 2: Deny TCP any → 203.0.113.10 port 80
- ○ C. Rule 1: Deny IP any any | Rule 2: Permit TCP any → 203.0.113.10 port 443
- ○ D. Rule 1: Permit UDP any → 203.0.113.10 port 443 | Rule 2: Deny IP any any

14. Firewall B at Adams County Hospital must ensure that only internal workstations on the 10.10.0.0/24 subnet can access the patient-records file server (10.0.0.5) over SMB (TCP port 445). All other traffic to the file server

must be denied.

Which ACL, applied on Firewall B's inbound interface, correctly implements this?

- ○ A. Permit TCP 10.10.0.0/24 → 10.0.0.5 port 80 | Deny IP any any
- ○ B. Permit IP 10.10.0.0/24 → any | Deny TCP any → 10.0.0.5 port 445
- ○ C. Permit TCP any → 10.0.0.5 port 445 | Deny IP any any
- ○ D. Permit TCP 10.10.0.0/24 → 10.0.0.5 port 445 | Deny IP any any

15. A network administrator configures the following ACL on a firewall:

Rule 1: Deny TCP 192.168.50.0/24 → 10.0.0.5 port 445
Rule 2: Permit TCP 192.168.50.0/24 → 10.0.0.5 port 445
Rule 3: Deny IP any any

A workstation at 192.168.50.25 attempts to open an SMB session with the file server at 10.0.0.5. What happens?

- ○ A. The connection is denied by Rule 1, because ACLs match top-to-bottom and the first matching rule wins.
- ○ B. The connection is permitted by Rule 2 because it is a more specific (explicit permit) rule that overrides the earlier deny.
- ○ C. The connection is permitted because Rule 3 is the final authority and it overrides both preceding rules.
- ○ D. The connection fails because SMB is blocked by default on all enterprise firewalls regardless of ACL configuration.

16. You are implementing Firewall A for Adams County Hospital. The requirements are:
(1) External patients can access the web application server (203.0.113.10) over both HTTPS (TCP 443) and HTTP (TCP 80).
(2) External DNS resolution requests (UDP port 53) to the hospital's public DNS server (203.0.113.20) must be permitted.
(3) All other inbound traffic must be denied and logged.

Which ACL set below correctly implements all three requirements?

- ○ A. 1. Permit IP any → 203.0.113.10
  2. Permit UDP any → 203.0.113.20 port 53
  3. Deny IP any any log
- ○ B. 1. Deny IP any any log
  2. Permit TCP any → 203.0.113.10 port 80
  3. Permit TCP any → 203.0.113.10 port 443
  4. Permit UDP any → 203.0.113.20 port 53
- ○ C. 1. Permit TCP any → 203.0.113.10 port 443
  2. Deny IP any any log
  3. Permit TCP any → 203.0.113.10 port 80
  4. Permit UDP any → 203.0.113.20 port 53
- ○ D. 1. Permit TCP any → 203.0.113.10 port 80
  2. Permit TCP any → 203.0.113.10 port 443
  3. Permit UDP any → 203.0.113.20 port 53
  4. Deny IP any any log

17. A junior administrator configures the following ACL on Firewall B to control access to the patient-records file server (10.0.0.5):

Rule 1: Permit TCP 10.10.0.0/24 → 10.0.0.5 port 445
Rule 2: Permit TCP 172.16.0.0/16 → 10.0.0.5 port 445
Rule 3: Permit TCP 203.0.113.10 → 10.0.0.5 port 445
Rule 4: Deny IP any any

A senior engineer flags Rule 3 as a critical security flaw. Which explanation is most accurate?

○ A. Rule 3 permits the DMZ web server to access the internal patient-records file server over SMB, enabling lateral movement from a compromised web server directly into systems containing protected health information.

○ B. Rule 3 is redundant because the 203.0.113.10 address falls within the range already covered by Rule 2.

○ C. Rule 3 is incorrectly written because a web server communicates on TCP 443, not TCP 445, making the rule syntactically invalid.

○ D. Rule 3 should specify UDP instead of TCP because web servers communicate with file servers using a connectionless protocol.

18. After configuring and deploying Firewall B at Adams County Hospital, which set of post-implementation actions most completely satisfies both security best practice and HIPAA audit requirements?

○ A. Reboot the firewall to apply the configuration and verify that the administrative web interface is reachable from the LAN.

○ B. Test that permitted traffic flows succeed, test that denied traffic is blocked, review firewall logs to confirm denied packets are being recorded, and produce documentation of the final ACL with a justification for each rule.

○ C. Export the ACL to a plain text file and email it to the IT director for sign-off.

○ D. Run an external port scan against the internal file server IP address to confirm that rules are blocking unauthorized access from the internet.